Общество с ограниченной ответственностью
«Вайлдберриз Банк»

УТВЕРЖДЕНО
Советом директоров
ООО «Вайлдберриз Банк»

Протокол № 3 от 31.01.2024г.

ООО «Вайлдберриз Банк»

_____ Бакин В.О.

ПОЛИТИКА ИНФОРМАЦИОННОЙ БЕЗОПАСНОСТИ ООО «ВАЙЛДБЕРРИЗ БАНК»

г. Москва
2024

1. Общие положения.

1.1. «Политика информационной безопасности ООО «Вайлдберриз Банк» (далее – Политика ИБ) является внутренним документом Общества с ограниченной ответственностью «Вайлдберриз Банк» (далее – Банк) и представляет собой систематизированное изложение целей и задач защиты, основных принципов построения, организационных, технологических и процедурных аспектов обеспечения необходимого уровня информационной безопасности Банка, его информационных активов, разработанным в соответствии с действующими законодательными актами, нормативными правовыми и иными актами Банка России, федеральных органов исполнительной власти (далее при совместном упоминании – законодательство), внутренними документами Банка.

1.2. Политика ИБ является документом первого уровня документов по обеспечению информационной безопасности Банка. Детальное описание правил и требований в области обеспечения ИБ приводится в частных политиках ИБ и иных внутренних документах Банка.

1.3. Положения настоящей Политики являются основополагающими для разработки внутренних документов, регламентирующих процедуры выполнения отдельных видов деятельности, связанных с обеспечением ИБ. Такие документы должны детализировать положения Политики и не противоречить им.

1.4. В рамках Политики ИБ используются понятия, термины и сокращения, приведенные в разделе 2 или специально указанные в ее тексте.

Нормативной основой Политики ИБ являются действующее законодательство Российской Федерации, нормативно-правовые акты государственных органов, уполномоченных в области обеспечения информационной безопасности, ГОСТы безопасности информационных технологий и обеспечения безопасности информационных систем, нормативные акты Центрального Банка Российской Федерации, накопленный Банком опыт и мировые практики в области обеспечения информационной безопасности, и основывается, в том числе, на требованиях следующих документов:

- Конституция РФ (ст. 23 определяет право граждан на тайну переписки, телефонных, телеграфных и иных сообщений);
- Уголовный кодекс РФ (ст. 272 устанавливает ответственность за неправомерный доступ к компьютерной информации, ст. 273 — за создание, использование и распространение вредоносных программ для ЭВМ, ст. 274 — за нарушение правил эксплуатации ЭВМ, систем и сетей);
- Национальный стандарт Российской Федерации ГОСТ Р 57580.1-2017 «Безопасность финансовых (банковских) операций. Защита информации финансовых организаций. Базовый состав организационных и технических мер»;
- Федеральный закон от 27.07.2006 г. № 149-ФЗ «Об информации, информационных технологиях и о защите информации»;
- Федеральный закон от 27.07.2006 г. № 152-ФЗ «О персональных данных» (далее - ФЗ №152);
- Федеральный закон от 06.04.2011 N 63-ФЗ «Об электронной подписи»;
- Федеральный закон от 27.06.2011 г. № 161-ФЗ «О национальной платежной системе»;

- Федеральный закон от 02.12.1990 г. № 395-1 «О банках и банковской деятельности»;
- Федеральный закон от 29.07.2004 г. № 98-ФЗ «О коммерческой тайне»;
- Положение Банка России от 17.04.2019 г. № 683-П «Об установлении обязательных для кредитных организаций требований к обеспечению защиты информации при осуществлении банковской деятельности в целях противодействия осуществлению переводов денежных средств»;
- Положение Банка России от 08.04.2020 г. №716-П «О требованиях к системе управления операционным риском в кредитной организации и банковской группе» (далее - Положение Банка России №716-П);
- Положение Банка России от 04.06.2020 г. №719-П «О требованиях к обеспечению защиты информации при осуществлении переводов денежных средств и о порядке осуществления Банком России контроля за соблюдением требований к обеспечению защиты информации при осуществлении переводов денежных средств»;
- Положение Банка России от 25.07.2022 г. №802-П «О требованиях к защите информации в платежной системе Банка России»;
- Положение Банка России от 12.01.2022 г. №787-П «Об обязательных для кредитных организаций требованиях к операционной надежности при осуществлении банковской деятельности в целях обеспечения непрерывности оказания банковских услуг»;
- Указание Банка России от 27.06.2023 N 6470-У "О формах, методиках составления, порядке и сроках представления отчетности оператора платежной системы, оператора услуг платежной инфраструктуры, оператора по переводу денежных средств в Центральный банк Российской Федерации";

1.5. В случае изменения действующего законодательства, внесения изменений в нормативные документы Банка России, федеральных органов исполнительной власти, а также во внутренние документы Банка, настоящая Политика, до ее приведения в соответствие с такими изменениями, действует в части, не противоречащей действующим законодательным и иным нормативно-правовым актам, а также соответствующим внутренним документам Банка.

2. Термины и определения.

Актив - все, что имеет ценность для Банка в интересах достижения целей деятельности и находится в его распоряжении (информационные активы, процессы, ПО, оказываемые услуги, персонал, материальные ценности и т.д.).

Автоматизированная банковская система (АБС) – автоматизированная система, реализующая банковский технологический процесс.

Автоматизированное рабочее место (АРМ) - совокупность рабочей станции пользователя и установленного на нее программного обеспечения, позволяющая выполнять определенные функциональные задачи.

Документ - зафиксированная на материальном носителе информация с реквизитами, позволяющими ее идентифицировать.

Информационная система (ИС) – совокупность информации и обеспечивающих ее

работу информационных технологий и технических средств.

Информационная система персональных данных (ИСПДн) – ИС, представляющая собой совокупность персональных данных (ПДн), содержащихся в базе данных, а также информационных технологий и технических средств, позволяющих осуществлять обработку таких персональных данных с использованием средств автоматизации или без использования таких средств.

Информационные ресурсы – информационные активы в информационных системах.

Информация – сведения (сообщения, данные) независимо от формы их представления.

Информационная безопасность (ИБ) – состояние защищенности банковских информационных технологических процессов, банковских платежных технологических процессов и бизнес-процессов Банка, объединяющих в своем составе работников Банка, автоматизированные системы, информационные системы, информационные ресурсы, информационные активы, автоматизированные рабочие места и информацию в условиях угроз нарушения их конфиденциальности, целостности и/или доступности.

Информационная инфраструктура - совокупность информационных систем, информационных ресурсов, информационных активов и каналов связи, обеспечивающая выполнение банковского информационного и банковского платежного технологических процессов.

Объект информационной инфраструктуры (ОИИ) – физический компонент информационной системы, ресурса, актива, канала связи, выполняющий свою часть банковского технологического процесса.

Менеджмент - скоординированная деятельность по руководству и управлению.

Мониторинг ИБ – постоянное наблюдение за объектами и субъектами, влияющими на обеспечение ИБ Банка, а также сбор, анализ и обобщение результатов наблюдений.

Несанкционированный доступ (НСД) – доступ к информации или действия с информацией, нарушающие установленные правила разграничения доступа.

Персональные данные (ПДн) – любая информация, относящаяся к прямо или косвенно определенному или определяемому физическому лицу (субъекту ПДн) в соответствии с определением ФЗ №152.

Работник Банка (**работник**) – лицо, с которым Банком установлены трудовые отношения (принятое на штатную должность в Банк, заключившее с Работодателем (Банком) трудовой договор и работающее как по основному месту работы, так и по совместительству) или отношения по договорам гражданско-правового характера (договорам подряда, на оказание услуг и т.п.).

Ресурс ИБ – кадровые ресурсы (персонал) подразделения, отвечающего за информационную безопасность в Банке, финансовые средства, необходимые для планирования, реализации, выполнения, проверки и совершенствования процессов СОИБ, материально-техническое обеспечение процессов защиты информации, используемые для достижения целевого уровня обеспечения информационной безопасности.

Ресурсное обеспечение ИБ – процесс управления, обеспечивающий определение потребностей в ресурсах информационной безопасности и контроль эффективности использования ресурсов информационной безопасности.

Риск - мера, учитывающая вероятность реализации угрозы и величину потерь (ущерба) от реализации этой угрозы.

Риск ИБ - риск реализации угроз ИБ, который заключается в возможности утраты свойств ИБ информационным активом в результате реализации угрозы ИБ, вследствие чего Банку может быть нанесен ущерб, и который обусловлен недостатками процессов обеспечения информационной безопасности, в том числе проведения технологических и других мероприятий, недостатками прикладного программного обеспечения автоматизированных систем и приложений, а также несоответствием указанных процессов деятельности Банка

Система информационной безопасности (СИБ) – совокупность защитных мер, защитных средств и процессов их эксплуатации, включая ресурсное и административное обеспечение ИБ Банка.

Система менеджмента информационной безопасности (СМИБ) – часть корпоративной системы менеджмента (управления) Банка, основанная на использовании методов оценки рисков информационной безопасности и предназначенная для создания, реализации, эксплуатации, мониторинга, анализа, поддержки и совершенствования системы обеспечения ИБ Банка.

Система обеспечения информационной безопасности (СОИБ) – совокупность СИБ и СМИБ.

Служба информационной безопасности (СИБ) – подразделение, ответственное за организацию, обеспечение, поддержание, контроль и анализ функционирования системы обеспечения информационной безопасности Банка.

Угроза - совокупность условий и факторов, которые могут стать причиной нарушения конфиденциальности, целостности и доступности.

Ущерб - утрата активов, повреждение (утрата свойств) активов и (или) инфраструктуры Банка или другой вред активам и (или) инфраструктуре Банка, наступивший в результате реализации угроз безопасности информации.

3. Цели, принципы и задачи обеспечения ИБ.

Главной целью ИБ Банка является обеспечение устойчивого функционирования Банка путем предотвращения угроз безопасности его информационным и техническим ресурсам; недопущение разглашения, утраты, утечки, искажения и уничтожения Информационных систем, а также, минимизация затрат на восстановление и ликвидацию последствий реализованных угроз, а именно угроз нарушения:

3.1. Конфиденциальности. Доступ к информационным активам должен предоставляться только авторизованным пользователям, объектам системы или процессам. Процессы обработки, хранения и передачи информации должны осуществляться таким образом, чтобы не допускать возможности несанкционированного распространения информации.

3.2. Целостности. Информационные активы должны сохранять неизменность в условиях случайного или преднамеренного искажения (разрушения), или исправлять обнаруженные изменения.

3.3. Доступности. Информационные активы должны беспрепятственно предоставляться авторизованным пользователям, причем в виде и месте, необходимым пользователям, и в то время, когда они им необходимы.

Для достижения основной цели обеспечения ИБ Банк решает следующие задачи:

3.4. назначение работника, ответственного за обеспечение ИБ в Банке;

3.5. управление документами и записями (включая идентификацию, классификацию, разработку и своевременную актуализацию документов и записей Банка в части ИБ)

3.6. инвентаризация и классификация информационных активов, представляющих ценность для Банка;

3.7. формирование моделей угроз и нарушителей ИБ;

3.8. управление рисками нарушения информационной безопасности, реализация которых является недопустимой для Организации;

3.9. мониторинг и управление инцидентами ИБ;

3.10. регулярное проведение внутренних и внешних аудитов ИБ;

3.11. постоянное обучение и повышение осведомленности работников в области ИБ;

3.12. управление доступом к Информационной инфраструктуре Банка;

3.13. оценка эффективности применяемых мер и средств обеспечения ИБ;

Функционирование СОИБ Банка должны соответствовать **следующим принципам**:

- Обоснованность - используемые возможности и средства СИБ должны быть реализованы на современном уровне развития науки и техники, обоснованы с точки зрения заданного уровня безопасности, эффективность которых доказана и может быть перепроверена по формализованным методикам.

- Комплексность - обеспечение защиты информационных активов от возможных угроз всеми доступными законными средствами, методами и мероприятиями, обеспечение согласованности организационных мер и мероприятий, инженерно-технических и программно-аппаратных средств, обеспечение безопасности информационных активов в течение всего их жизненного цикла, на всех технологических этапах их обработки и использования, во всех режимах функционирования.

- Непрерывность - постоянное поддержание СОИБ в актуальном состоянии и совершенствование ее в соответствии с изменяющимися условиями функционирования Банка.

- Законность - предполагает разработку СОИБ Банка на основе требований нормативных актов Центрального банка Российской Федерации, Федерального законодательства в области банковской деятельности, информатизации и защиты информации и других нормативных актов по безопасности, утвержденных органами государственного управления в пределах их компетенции, с применением всех дозволенных методов обнаружения и пресечения правонарушений.

- Специализация - эксплуатация технических средств и реализация мер по обеспечению информационной безопасности должны осуществляться профессионально подготовленными специалистами по ИБ.

- Взаимодействие и координация - осуществление мер обеспечения информационной безопасности на основе четкой взаимосвязи соответствующих подразделений и служб, координации их усилий для достижения поставленных целей.

- Совершенствование - развитие мер и средств СОИБ на основе накопленного опыта, использования новых технических средств.

- Централизация управления - управление информационной безопасностью по единым организационным, функциональным и методологическим принципам.

- Независимость - разработчики системы по обеспечению информационной безопасности не должны контролироваться субъектами защиты.

- Системность - при построении системы обеспечения информационной безопасности должны учитываться все факторы и аспекты деятельности Банка, которые влияют или могут оказать влияние на состояние информационной безопасности.

- Непрерывность - обеспечение безопасности является непрерывным процессом и не может быть обеспечено одноразовым действием.

- Своевременность - методы и средства защиты должны носить упреждающий характер по отношению к угрозам информационной безопасности.

- Экономическая эффективность - затраты на систему защиты не должны превышать размеры возможного ущерба.

- Враждебность - система информационной безопасности должна создаваться исходя из предположения, что субъекты защиты имеют наихудшие намерения, они будут совершать серьезные ошибки и искать пути обхода механизмов защиты.

- Минимизация привилегий - каждый пользователь должен иметь минимальный набор привилегий, необходимых для работы.

- Разделение полномочий - работник не должен иметь возможности произвести в одиночку всю совокупность критических действий.

- Разделение ответственности - каждый должен нести персональную ответственность за свои действия, при этом информационную систему и систему по обеспечению информационной безопасности следует строить так, чтобы действия пользователей были как можно более изолированными друг от друга.

- Персонификация - полномочия при определении порядка доступа пользователей и администраторов к защищаемым ресурсам должны быть персональными, указанными явно и проверенными непосредственно перед предоставлением доступа.

- Нестандартность - система по обеспечению информационной безопасности должна быть разнообразной по используемым средствам, и связям между ними, многоуровневой с иерархической последовательностью доступа к информации.

- Независимость от алгоритмов защиты - система защиты не должна зависеть от конфиденциальности её алгоритмов построения и функционирования. Знание алгоритмов работы системы защиты не должно давать возможности её преодоления, в том числе и её разработчикам.

- Обязательность контроля. В Организации должны применяться только те защитные меры, правильность работы которых может быть проверена. Для получения уверенности в эффективности применяемых защитных мер необходимо осуществлять их постоянный мониторинг и контроль. Результаты контроля должны использоваться при принятии решений о совершенствовании системы защиты.

- Персональная ответственность. Ответственность за обеспечение информационной безопасности должна возлагаться на каждого работника в части, его касающейся.

Кроме того, при распределении прав доступа работников и клиентов к информационным активам Банк руководствуется следующими принципами:

- «Знать своего клиента». Принцип, используемый регулирующими органами для выражения отношения к финансовым организациям с точки зрения знания деятельности их клиентов. Использование этого принципа призвано снизить вероятность того, что Организация может стать жертвой противозаконных действий своих клиентов. В рамках реализации данного принципа Организации следует тщательно относиться к проверке личности клиента, а также обращать внимание на любые необычные операции или на операции, которые непропорциональны известной деловой деятельности клиента.

- «Знать своего служащего». Принцип, демонстрирующий озабоченность Организации по поводу отношения служащих к своим обязанностям и возможных проблем, таких, как злоупотребление имуществом, аферы или финансовые трудности, которые могут приводить к проблемам с безопасностью.

- «Необходимо знать». Принцип, ограничивающий полномочия по доступу к информации и ресурсам по обработке информации на уровне минимально необходимых для выполнения определенных обязанностей.

- «Двойное управление». Принцип сохранения целостности процесса и борьбы с искажением функций системы, требующий дублирования (алгоритмического, временного, ресурсного или иного) действий до завершения определенных транзакций.

Главными задачами защиты Информационных систем в Банке являются:

- создание оптимальной системы защиты Информационных систем, обеспечивающей достижение поставленных целей защиты наиболее надёжным способом;
- обеспечение наиболее эффективного выполнения системой своих защитных функций в процессе ее функционирования;
- минимизация потерь Банка при реализации угроз ИБ и максимально быстрое восстановление программных и аппаратных средств, Информационных систем, пострадавших в результате реализации угроз ИБ;
- оценка действительной эффективности проводимых мероприятий по защите Информационных систем, (оценка уровня ИБ проводится сторонними компаниями, имеющими лицензии ФСТЭК России на осуществление деятельности по защите информации);
- своевременное выявление угроз ИБ Банка;
- контроль состояния ИБ на всех этапах ЖЦ ИС;
- обеспечение реализации требований законодательства Российской Федерации по защите персональных данных, банковской тайны, а также норм финансовых регуляторов в части ИБ кредитных организаций и мер контроля защищенности.

4. Объекты защиты.

Основными объектами защиты в Банке являются:

- информационная инфраструктура Банка, включающая технические средства обработки, хранения, передачи и отображения информации, системы и средства защиты информации, каналы передачи данных и иные телекоммуникации, а также объекты и помещения, в которых располагаются компоненты информационной инфраструктуры Банка;
- процессы обработки информации в информационной системе Банка, включающие информационные технологии, регламенты и процедуры сбора, обработки, хранения и передачи информации;
- информационные активы;

С точки зрения информационной безопасности, Банк определяет следующие типы информационных активов, являющихся значимыми для осуществления своей деятельности:

- информационные ресурсы ограниченного доступа:
  - информация, составляющая банковскую тайну;
  - информация, составляющая коммерческую тайну;

- платежная информация (информация, предназначенная для проведения банковских операций и учетных операций);
- данные держателей платежных карт (включая персональные данные);
- управляющая информация платежных, информационных и телекоммуникационных систем (информация, используемая для технической настройки программно-аппаратных комплексов обработки, хранения и передачи информации);
- иная конфиденциальная информация, находящаяся в распоряжении Организации и имеющая для неё ценность, доступ к которой должен быть ограничен в соответствии с требованиями внутренних документов Организации или иных нормативных актов;

5. Угрозы информационной безопасности.

Под угрозой информационной безопасности в настоящей Политике понимается потенциальная возможность нарушения свойств ИБ — доступности, целостности или конфиденциальности информационных активов Банка.

Угрозы ИБ реализуются их источниками (источниками угроз ИБ), которые могут воздействовать на объекты среды информационных активов Банка, и имеют соответствующую вероятность реализации. В случае успешной реализации угрозы ИБ информационные активы теряют часть или все свойства ИБ.

Источники угроз используют для реализации угрозы уязвимости ИБ.

Корректное определение и прогнозирование возможных угроз и степени их опасности для деятельности Банка являются одним из главных инструментов в обеспечении ИБ и необходимы для обоснования, выбора и реализации защитных мероприятий.

По природе возникновения источники угроз информационной безопасности могут носить природный, техногенный или антропогенный характер. Источники угроз антропогенного характера могут быть как злоумышленные, так и незлоумышленные.

По отношению к информационной системе источники угроз могут быть внутренними и внешними.

При создании и совершенствовании СОИБ Банка следует рассматривать следующие классы источников угроз:

- источники угроз ИБ, связанные с неблагоприятными событиями природного, техногенного и социального характера (стихийные бедствия, пожар, техногенные катастрофы, нарушение электропитания, сбой в системах отопления, водоснабжения и канализации, угрозы здоровью персонала);
- источники угроз ИБ, связанные с деятельностью террористов и лиц, совершающих преступления и правонарушения (террористические действия, вандализм, шпионаж, шантаж, социальный инжиниринг);
- источники угроз ИБ, связанные с деятельностью поставщиков/провайдеров/партнеров (нарушение договорных обязательств, разработка некачественной документации, ошибки в обеспечении безопасности ИС на стадиях жизненного цикла);
- источники угроз ИБ, связанные со сбоями, отказами, разрушениями/повреждениями программных и технических средств (сбои, отказы,

повреждения и аварии технических средств и каналов связи, нарушения функциональности различных систем, превышение допустимой нагрузки);

- источники угроз ИБ, связанные с деятельностью внутренних нарушителей ИБ (несоблюдение инструкций и правил ИБ, использование информационных активов не по назначению, халатность, хищение, причинение имущественного ущерба, неавторизованные действия, направленные на нарушение заданных свойств ИБ информационных активов);
- источники угроз ИБ, связанные с деятельностью внешних нарушителей ИБ (действия неавторизованного субъекта, направленные на нарушение заданных свойств ИБ информационных активов);
- источники угроз ИБ, связанные с несоответствием требованиям надзорных и регулирующих органов, действующему законодательству.

6. Обеспечение информационной безопасности персональных данных

При осуществлении деятельности Банк вступает в отношения, связанные с обработкой персональных данных (ПДн) и является, таким образом, оператором персональных данных.

В Банке обеспечивается защита персональных данных, обрабатываемых в информационных системах персональных данных (ИСПДн), от несанкционированного доступа, использования, передачи, разглашения, модификации (изменения) или уничтожения. Безопасность персональных данных обеспечивается комплексом организационных и технических мер, которые регулируются отдельными частными политиками информационной безопасности Организации.

В Организации назначено лицо, ответственное за организацию обработки персональных данных, а также лицо или подразделение, ответственное за обеспечение информационной безопасности персональных данных, обрабатываемых в ИСПДн Организации

7. Управление рисками ИБ

7.1 Меры по нейтрализации умышленной дезорганизации работы, вывода ОИИ из строя, проникновения в ОИИ и НСД к информации и снижению возможного наносимого ими ущерба включают:

- организационные меры (регламентация действий, введение ограничений, подбор, расстановка и работа с персоналом, усиление ответственности и контроль за действиями персонала);
- применение программно-технических средств, препятствующих умышленному совершению нарушения;
- резервирование критичных информационных ресурсов;
- применение средств шифрования;
- обеспечение физической безопасности ресурсов Банка, в т.ч. его работников.

7.2. Меры по нейтрализации непреднамеренных угроз ИБ ОИИ и снижению возможного наносимого им ущерба, помимо указанных выше, включают:

- применение технологических средств контроля вводимых данных, разграничения доступа, резервирования ресурсов;
- применение технических и технологических средств контроля процессов

управления доступом, состоянием, резервированием и конфигурированием ресурсов.

7.3. Оценка рисков нарушения ИБ осуществляется в соответствии с действующей методикой оценки рисков нарушения информационной безопасности.

7.4. Методика оценки рисков нарушения ИБ определяет способ и порядок качественного или количественного оценивания риска нарушения ИБ на основании:

- степени вероятности реализации угроз ИБ выявленными и (или) предполагаемыми источниками угроз ИБ, зафиксированными в моделях угроз и нарушителя, в результате их воздействия на объекты информационных активов Банка (типов информационных активов);

- степени тяжести последствий от потери свойств ИБ для рассматриваемых информационных активов Банка (типов информационных активов).

7.5. Задачи управления рисками информационной безопасности прописаны во внутреннем нормативном документе «Частная политика по обеспечению информационной безопасности и операционной надежности банковских платежных технологических процессов в ООО «Вайлдберриз Банк».

8. Требования по обеспечению информационной безопасности.

8.1. Выполнение требований ИБ является обязательным для всех работников Банка.

8.2. Руководством Банка уделяется особое внимание обеспечению ИБ Банка и контролю выполнения требований ИБ. Контроль выполнения требований по обеспечению ИБ проводится в соответствии с внутренними нормативными документами.

8.3. На основании оценки рисков ИБ разрабатывается стратегия Банка в части противодействия угрозам ИБ, включающая в себя реализацию организационных и технических мер по обеспечению ИБ.

8.4. С целью реализации, контроля и поддержания на должном уровне СОИБ в Банке на всех этапах жизненного цикла информационных активов Банка управление ИБ Банка осуществляется с соблюдением законодательства, нормативных документов Банка России и иных регулирующих органов в области ИБ.

8.5. В Банке определяются, выполняются, регистрируются и контролируются процедуры выявления, учета и классификации информационных активов. Права доступа работников и клиентов Банка к информационным активам и (или) их типам учитываются , фиксируются и регулярно пересматриваются.

8.6. На всех АРМ и серверах АБС применяются средства защиты от вредоносного кода, если иное не предусмотрено реализацией технологического процесса, или результатами анализа рисков.

8.7. Обеспечение ИБ обеспечивается на всех на стадиях жизненного цикла информационных систем.

8.8. Банк, являясь оператором ПДн, выполняет все необходимые мероприятия по защите ПДн в порядке и в сроки, установленные Федеральным законом от 27.07.2006 г. №152-ФЗ «О персональных данных».

8.9. В Банке определяются, выполняются и контролируются процедуры учета ПДн, ИСПДн, а также учета лиц, имеющих доступ к ПДн.

8.10. В Банке назначается лицо, ответственное за организацию обработки ПДн. Полномочия, права и обязанности лица, ответственного за организацию обработки ПДн,

устанавливаются в соответствии с требованиями закона РФ.

8.11. Для защиты конфиденциальной информации при ее обработке, хранении и передаче по каналам связи могут использоваться СКЗИ. Решение об использовании СКЗИ на каждом конкретном ОИИ Банк принимает самостоятельно, если иное не предусмотрено действующим законодательством, требованиями регулирующих органов и/или условиями заключенных Банком договоров.

9812. В Банке применяются меры, направленные на обеспечение защиты от НСД, повреждения или нарушения целостности данных о действиях и операциях, а также меры по защите информации, необходимой для идентификации, аутентификации и (или) авторизации клиентов и работников Банка. Все попытки НСД к такой информации подлежат регистрации.

8.13. В Банке определяются, выполняются, регистрируются и контролируются правила и процедуры мониторинга, анализа и хранения данных о действиях и операциях, позволяющие выявлять неправомерные или подозрительные операции и (или) транзакции.

8.14. В Банке разрабатываются планы, программы обучения и повышения осведомленности в области ИБ.

9. Контроль за соблюдением положений Политики.

9.1. Общий контроль за состоянием ИБ Банка и соблюдением требований настоящей Политики осуществляется Заместителем Председателя Правления, ответственном за обеспечение информационной безопасности в Банке.

9.2. Текущий контроль за соблюдением требований настоящей Политики осуществляется подразделениями Банка.

9.3. Контроль полноты и правильности выполнения положений настоящей Политики осуществляется Службой внутреннего аудита Банка в ходе проведения проверок, периодичность проведения которых определяется соответствующими внутренними документами Банка.

10. Пересмотр и внесение изменений.

10.1. Настоящая Политика действует до момента утверждения её новой редакции или до принятия решения о признании её утратившей силу. В случае утверждения изменений или дополнений к ней, Политика продолжает действовать с учетом принятых изменений, дополнений.

10.2. Предложения по внесению изменений и дополнений в настоящую Политику, изданию новой редакции Политики вносятся ответственным подразделением и подлежат согласованию в порядке, установленном внутренними документами Банка.

10.3. Настоящая Политика подлежит пересмотру:

- при выявлении недостатков в системе обеспечения ИБ;

- при изменении стратегии, основных принципов и приоритетов в защите информации Банка.

10.4. Основаниями для пересмотра настоящей политики являются:

- изменение требований законодательства Российской Федерации в области защиты информации, изменение требований регуляторов или платёжных систем, участником которых является Банк;

- изменение организационной структуры Банка;

- изменения технологических и бизнес процессов Банка;

- результаты проверок выполнения требований ИБ;

- обоснованные предложения со стороны работников Банка по внесению изменений в документ.

11. Ответственность.

11.1. Ответственным подразделением за обеспечение ИБ в Банке, а также разработку и актуализацию настоящей Политики является Служба информационной безопасности.

11.2. Требования настоящей Политики обязательны для выполнения всеми работниками Банка.

11.3. Работники Банка, нарушившие положения настоящей Политики, могут быть привлечены к дисциплинарной, гражданско-правовой и иной ответственности, установленной законодательством Российской Федерации и (или) условиями трудового соглашения (контракта).